

Clase 1

Seguridad de la informacion

¿Que se debe asegurar? → La información nuestra y la de la organización.

Principios básicos (CIA Triad)

- Confidencialidad Garantiza que la información sólo sea accesible por las personas autorizadas En otras palabras proteger la información contra accesos no autorizados
- Integridad Garantiza que la información sólo pueda ser modificada por quien está autorizado a hacerlo En otras palabras proteger la información contra accesos no autorizados
- Disponibilidad Garantiza que los usuarios autorizados tienen acceso a la información y recursos relacionados cuando lo necesiten

Vectores de ataque con IA

- Operaciones de influencia → Engaños con imagenes generadas por IA y deepfakes
- Ingenieria social → Phishing y Vishing (Cloning as a Service, VCaaS)
- Servicios y colaboracion en la Deep Web con IA-como-servicio
 - Herramientas maliciosas de IA para identificando vulnerabilidades para explotarlas
 - Participantes en estos foros han anunciado chatbots personalizados con IA, diseñados para crear programas maliciosos.
- Engaños con imágenes generadas por IA y deepfakes
 - Caso de uso 1: Actores de amenazas patrocinados por el estado usan imágenes generadas por IA para difundir propaganda en redes sociales.
 - Caso de uso 2: Actores de amenazas utilizan videos deepfake en vivo haciéndose pasar por un ejecutivo para engañar a un empleado de finanzas y hacer que transfiera millones a una cuenta maliciosa.
 - Caso de uso 3: Imágenes generadas por IA aumentan la interacción de los empleados en campañas de phishing

¿Que es la criptografía?

Ciencia de proteger información mediante técnicas matemáticas.

Cifrado: proceso específico de codificar la información

Tipos de criptografía

- Simetrica
- Asimetrica
- Hash (SHA, MD5)

sinmetrica	asimetrica	hash
El cifrado simétrico implica el uso de una única clave privada. Imaginemos que un cliente transmite datos a un servidor. El cliente cifra los datos con la clave privada y luego los transmite. Posteriormente, el servidor los descifra utilizando esa misma clave. Como el proceso implica una sola clave, el cifrado simétrico es rápido. Sin embargo, también es más vulnerable a ataques. La misma clave se comparte con cualquiera que desee descifrar el mensaje, lo que aumenta la probabilidad de que un atacante la intercepte. Un ejemplo común de algoritmo de cifrado simétrico es el Estándar de Cifrado Avanzado (AES). Este algoritmo protege los datos en aplicaciones que utilizan bancos, organismos gubernamentales y empresas de comunicaciones.	El cifrado asimétrico es simplemente otro nombre para la criptografía de clave pública. El servidor y el cliente establecen cada uno su propio par de claves: una clave pública y una clave privada. Para que un cliente transmita datos a un servidor, primero cifra los datos utilizando la clave pública del servidor y luego los transmite. A continuación, el servidor descifra los datos utilizando su clave privada. El cifrado asimétrico es más lento que el simétrico porque implica varias claves. Pero también es más seguro porque ninguna de las partes comparte la clave privada utilizada para descifrar los datos. El algoritmo Rivest-Shamir-Adleman (RSA) es un ejemplo de cifrado asimétrico. Adobe Acrobat utiliza una forma de RSA para el cifrado y las firmas digitales.	Funcion de hash (codigo de huella digital) Transformacion unidireccional de datos en un valor de longitud fija Util para verificar integridad (no para cifrar) El NIST desaconsejo formalmente el uso SHA-1 en 2011, En 2017 los principales navegadores web dejaron de aceptar certificados SSL basados en SHA-1 Ejemplos actuales: SHA-2 (SHA-256, SHA-384, SHA-512) o SHA3

Criptografía: Vulnerabilidades y ataques.

- Fuerza bruta
- Criptoanálisis (lineal)
- Ataques a implementaciones side channel time based
- Importancia de usar algoritmos actualizados

TENDENCIAS ACTUALES

- Criptografía poscuántica: Conjunto de algoritmos criptográficos diseñados para resistir ataques de computadores cuánticos, basados en problemas matemáticos distintos a factorización o logaritmos discretos.
- Homomorphic encryption: Técnica criptográfica que permite realizar operaciones sobre datos cifrados sin necesidad de descifrarlos, preservando la confidencialidad durante el procesamiento.
- Zero-knowledge proofs

Protocolos Criptograficos en Ciberseguridad

- TLS/SSL (HTTPS) - Protege la comunicacion entre navegador y servidor. Combina criptografica ASIMETRICA (por intercambio inicial) y simetrica (para el canal seguro). Certificados digitales → Garantizan la identidad del sitio.
- VPN (Redes privadas virtuales)
Tuneles seguros sobre internet
Usan cifrado SIMETRICO y autenticacion con certificados o credenciales.
Garantizan confidencialidad y privacidad en redes publicas
- Firma Digital y PKI
Basada en criptografía asimétrica
Garantiza integridad, autenticidad y no repudio
Ejemplo: firma de documentos PDF, trámites gubernamentales
- Autenticación Multifactor 2FA/MFA)
Combinación de criptografía y protocolos (ej TOTP/HOTP para códigos temporales)
Mejora la seguridad frente a robo de contraseñas

Autenticacion Multifactor (MFA)

Método de autenticación que requiere dos o más factores independientes para verificar la identidad del usuario

Factores principales

Algo que sabes → contraseña, PIN.

Algo que tienes → token, tarjeta inteligente, app móvil.

Algo que eres → huella dactilar, reconocimiento facial, iris.

Objetivo aumentar la seguridad reduciendo el riesgo de accesos indebidos si una credencial es comprometida

Técnicas comunes de MFA

- Contraseña OTP One Time Password
 - Código temporal de un solo uso.
 - Puede recibirse por SMS,
 - correo electrónico
 - app autenticadora.
 - Ejemplo: Google Authenticator , Authy
- Tokens físicos o llaves de seguridad:
 - Dispositivos como YubiKey o tarjetas inteligentes (Smart Cards)
 - Usan estándares como FIDO2 / U2F.
- Push Notification:
 - Confirmación desde una app móvil (ej. Microsoft Authenticator , Duo Security)
 - Más simple para el usuario, menos dependiente de SMS.
- U2F (Universal 2nd Factor)

Estándar abierto creado por FIDO Alliance y Google/ Yubico 2014 para implementar un segundo factor de autenticación

 - Cómo funciona
 - El usuario se autentica con su contraseña.
 - Se conecta un dispositivo físico (ej. llave USB o NFC).
 - Usa criptografía de clave pública para validar la identidad.
 - Ventajas
 - Muy resistente a phishing y robo de credenciales.
 - Compatible con navegadores y servicios principales (Google, GitHub).
 - Ejemplo Usuario contraseña llave de seguridad (ej YubiKe)

- FIDO2
 - Evolución de U 2 F lanzada en 2018 por FIDO Alliance y W 3 C
 - Componentes
 - WebAuthn (Web Authentication API): estándar web que permite a navegadores usar autenticación sin contraseña.
 - CTAP2 (Client to Authenticator Protocol 2): protocolo que permite a llaves de seguridad y dispositivos (ej. smartphones) actuar como autenticadores.
 - Características
 - Passwordless acceso sin necesidad de contraseñas
 - Uso de biometría, PIN o llaves físicas.
 - Mayor integración en sistemas operativos y navegadores modernos.
 - Ejemplo Iniciar sesión en un sitio confirmar con huella en el celular o con una llave de seguridad

Métodos avanzados de MFA

Biometría

- Huella dactilar, reconocimiento facial, voz, iris.
- Combinado con otro factor, aumenta la seguridad.

Basado en ubicación o contexto

- Verificación de la geolocalización, dirección IP o dispositivo.
- Ejemplo: acceso bloqueado si se detecta desde país inusual.

Códigos TOTP/HOTP

- TOTP (Time based One Time Password): caducan cada 30 60 segundos.
- HOTO (HMAC based One Time Password): cambia con un contador de

Autenticación adaptativa o de riesgo

- El sistema ajusta el nivel de verificación según el riesgo detectado (ej. acceso desde dispositivo nuevo → pide MFA adicional).

Autenticacion con OTP

- HOTP (HMAC - Based One-Time Password)
 - Genera un codigo unico usando un contador (event-based)
 - Cada vez que el usuario solicita acceso, el contado avanza y produce un nuevo codigo

- TOTP (Time-based One time password) Variante de HOTP basada en tiempo
 - El código cambia automáticamente cada 30 o 60 segundos
 - Usado por apps como Google Authenticator, AuthT, Microsoft Authenticator
- Características Comunes
 - Basados en CRIPTOGRAFIA
 - Requieren clave compartida (seed) entre el servidor y el generador de códigos
 - Refuerzan el 2DA/MFA → Incluso si la contraseña se filtra, el atacante necesita el OTP

Tipos de Amenazas

- **Ingeniería Social** → Engaños para obtener información confidencial.
- **Phishing** → Combinación de ingeniería social + elementos técnicos (ej. mails falsos).
 - Señales: correos alarmistas, errores gramaticales, saludos genéricos, urgencia sospechosa.
- **Tailgating** → Ingreso físico no autorizado siguiendo a una persona legítima.
- **Baiting** → USB infectado colocado en lugares públicos.
- **Botnets** → Red de hosts infectados controlados por un *bot master* (robo de credenciales, SPAM, DDoS).
- **DoS/DDoS** → Ataque para agotar recursos y volver un sistema inaccesible (técnicas: amplificación, reflexión).
- **Malware** → Software malicioso (Virus, Gusano, Troyano, Spyware, Keylogger, Backdoor, Ransomware).
- **APT (Advanced Persistent Threats)**: Grupos estatales o corporativos, ataques prolongados y sofisticados
- **Hacktivismo**: Uso político o social de ataques digitales
- **Cibercrimen Organizado**: Ransomware Gangs, explotación de vulnerabilidades como servicio (VaaS)

- **Buffer Overflow:** escribir fuera de los límites de memoria puede ejecutar código arbitrario
- **Inyecciones SQL:** Manipulación de consultas a bases de datos mediante entradas no validadas
- **Cross-Site Scripting (XSS):** Inyección de scripts en páginas web para robar cookies o credenciales.
- **Meltdown:** Procesadores Intel (y algunos ARM) que permitía a un programa leer memoria del kernel u otros procesos
 - Cómo funciona: Aprovecha la ejecución especulativa y la falta de aislamiento estricto entre memoria de usuario y memoria privilegiada.
 - Impacto: Filtración de contraseñas, claves de cifrado o cualquier dato sensible almacenado en memoria.
 - Mitigación: Actualizaciones de microcódigo, parches en sistemas operativos (kernel page table isolation KPTI).
- **Spectre:** mas general, afecta procesadores Intel, AMD y ARM
 - Cómo funciona: Engaña al predictor de saltos de la CPU para ejecutar instrucciones especulativas que acceden a memoria no autorizada.
 - Impacto: Exposición de datos entre procesos aislados → rompe la idea de "sandboxing" en navegadores y máquinas virtuales.
 - Mitigación: Cambios en compiladores (inserción de retpolines), actualizaciones de microcódigo y rediseño en hardware.